



INDIAN INSTITUTE OF TECHNOLOGY ROORKEE

Cloud Security (CST-109)

Assignment 4
(Continuation to Assignment 3)

Public Cloud (AWS) - *Flexible to use any free cloud platform*

Note: *Ensure the entire implementation is done within the free-tier limits of AWS*

1. Set up user authentication using **Amazon Cognito** by creating a user pool, registering users, and enabling login with username and password. Ensure that a JWT token is generated after successful authentication.
2. Implement authorization using **AWS Identity and Access Management** by creating roles, defining appropriate policies, and restricting access to resources based on roles.
3. Create and secure an API using **Amazon API Gateway**, where access is allowed only to users with valid JWT tokens using a Cognito authorizer. Simulate attack scenarios such as invalid login attempts, accessing APIs without a token, and using expired or incorrect tokens, and observe how the system responds to unauthorized access.
4. Monitor system activity using **Amazon CloudWatch** by capturing logs for authentication events, API access, and errors, and identify any suspicious patterns.

Private Cloud

Integrate the following in a distributed system with an API gateway and multiple backend servers.

1. Design a basic authentication system where users can register and log in using username and password. After successful login, generate a *JWT token* and use it to access protected routes. Maintain logs for successful and failed login attempts.
2. Extend the system with *Role-Based Access Control (RBAC)* by assigning roles such as Admin and User. Include role information in the JWT and restrict access to APIs. Log all authorized and unauthorized access attempts.

3. Simulate security attacks on the IAM system by performing brute-force login attempts and accessing resources using invalid tokens. Record all failed logins and unauthorized access in logs to identify suspicious behavior.
4. Implement automated security mechanisms such as token expiration, block repeated login attempts, account lockout after multiple failed attempts. Ensure mitigation actions are triggered automatically and logged properly.